

Document de Conformite RGPD & AI Act

Projet Thumalien - Analyse d'Impact et Mesures de Conformite

Reference : RGPD-THUM-2026-001

Version : 1.0

Statut : En vigueur

Date : Avril 2026

Responsable : Chef de Projet Data / DPO delegue

Classification : Confidentiel - Usage interne

1. Objet et perimetre

Ce document formalise la conformite du projet Thumalien au Reglement General sur la Protection des Donnees (RGPD - UE 2016/679) et anticipe les exigences du Reglement sur l'Intelligence Artificielle (AI Act - UE 2024/1689).

Perimetre couvert :

- Collecte de posts publics sur Bluesky
- Stockage dans MongoDB
- Traitement par les modeles d'IA (detection de fake news + analyse emotionnelle)
- Affichage sur le dashboard Streamlit

2. Analyse d'impact relative a la protection des donnees (AIPD)

2.1 Le traitement necessite-t-il une AIPD ?

Selon l'article 35 du RGPD, une AIPD est obligatoire lorsque le traitement est susceptible d'engendrer un risque eleve pour les droits et libertes des personnes physiques.

Critere CNIL	Applicable ?	Justification
Evaluation/scoring	Oui	Score de credibilite attribue a des contenus
Decision automatisee avec effet juridique	Non	Le score est indicatif, aucune decision automatisee
Surveillance systematique	Partiellement	Collecte continue mais sur posts publics uniquement
Donnees sensibles (Art. 9)	Non	Pas de collecte d'opinions politiques, religion, sante en tant que telles

Donnees a grande echelle	Oui	188 553 posts collectes
Croisement de donnees	Non	Pas de croisement avec d'autres bases
Personnes vulnérables	Non	Pas de ciblage de populations vulnérables
Usage innovant de technologies	Oui	IA appliquee a la detection de desinformation
Exclusion du benefice d'un droit	Non	Aucune exclusion resultant du traitement

Conclusion : 3 criteres sur 9 sont remplis. Selon les lignes directrices du CEPD, une AIPD est recommandee (seuil a 2 criteres). Nous procedons donc a cette analyse.

2.2 Description du traitement

Element	Detail
Finalite	Recherche academique : detection de desinformation et analyse emotionnelle sur les reseaux sociaux
Base legale	Interet legitime (Art. 6.1.f) - recherche academique sur des donnees publiques
Categories de donnees	Textes de posts publics, pseudonymes (handles Bluesky), dates de publication, metadonnees d'engagement (likes, reposts)
Personnes concernees	Utilisateurs de Bluesky dont les posts sont publics
Destinataires	Equipe projet uniquement (pas de partage avec des tiers)
Duree de conservation	Donnees brutes : 12 mois. Donnees anonymisees : indefinie
Transferts hors UE	Oui - les serveurs Bluesky sont aux Etats-Unis. La collecte transite par l'API publique
Sous-traitants	Aucun sous-traitant externe

2.3 Evaluation des risques

Risque 1 - Reidentification des auteurs

Attribut	Evaluation
Description	Les handles Bluesky (ex: user.bsky.social) permettent d'identifier les auteurs
Gravite	Moyenne - les posts sont deja publics sur Bluesky
Probabilite	Elevee - le handle est stocke en clair
Niveau de risque	Modere
Mesure d'attenuation	Pseudonymisation : le dashboard n'affiche pas les handles. Les analyses sont agregees, jamais par auteur. Possibilite de hachage des handles dans une version future

Risque residuel	Faible
-----------------	--------

Risque 2 - Stigmatisation par le score de credibilite

Attribut	Evaluation
Description	Un post classe "suspect" pourrait etre interprete comme une accusation envers son auteur
Gravite	Elevee - atteinte a la reputation
Probabilite	Faible - le score est applique au texte, pas a l'auteur, et n'est pas publie
Niveau de risque	Modere
Mesure d'attenuation	Le score est presente comme indicatif. Le dashboard mentionne explicitement que "suspect" signifie "contient des patterns stylistiques de desinformation" et non "est faux". Pas de profilage par auteur
Risque residuel	Faible

Risque 3 - Biais discriminatoire du modele

Attribut	Evaluation
Description	Le modele pourrait systematiquement classifier certaines langues, sujets ou communautes comme "suspectes"
Gravite	Elevee - discrimination algorithmique
Probabilite	Moyenne - le biais Reuters a deja ete identifie et corrige, mais d'autres biais peuvent subsister
Niveau de risque	Modere a eleve
Mesure d'attenuation	Audit de biais documente (ecart F1 FR/EN < 2 points), datasets d'entrainement diversifies (6 sources), transparence sur les limites du modele dans la page Metriques. Tests reguliers d'equite prevus
Risque residuel	Modere - surveillance continue necessaire

Risque 4 - Fuite de donnees

Attribut	Evaluation
Description	Acces non autorise a la base MongoDB contenant les posts et metadonnees
Gravite	Moyenne - donnees deja publiques sur Bluesky
Probabilite	Faible - infrastructure locale, pas d'exposition internet
Niveau de risque	Faible
Mesure d'attenuation	MongoDB accessible uniquement sur le reseau Docker interne. Pas de port expose en production. Identifiants dans fichier .env non versionne

Risque residuel	Tres faible
-----------------	-------------

2.4 Bilan des mesures de conformite

Risque initial : MODERE

Mesures implementees : 12 (voir section 3)

Risque residuel : FAIBLE a MODERE

Avis : Le traitement peut etre mis en oeuvre sous reserve du suivi des mesures

3. Mesures de conformite RGPD implementees

3.1 Principes fondamentaux (Articles 5 et 6)

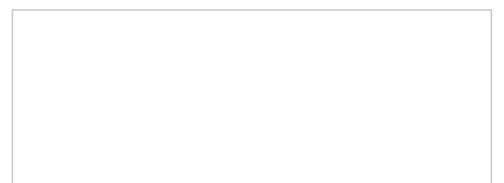
Principe	Mesure implementee	Statut
Liceite (Art. 6.1.f)	Base legale : interet legitime pour la recherche academique. Les posts sont publics et collectes via une API ouverte	Conforme
Limitation des finalites (Art. 5.1.b)	Les donnees ne sont utilisees que pour la detection de desinformation et l'analyse emotionnelle. Pas de finalite commerciale, pas de revente	Conforme
Minimisation (Art. 5.1.c)	Seuls les champs necessaires sont collectes (texte, date, handle, metriques d'engagement). Pas de collecte de donnees de profil, de reseau social ou de contenus prives	Conforme
Exactitude (Art. 5.1.d)	Les donnees sont collectees directement depuis l'API Bluesky sans modification du contenu original	Conforme
Limitation de conservation (Art. 5.1.e)	Politique de retention : 12 mois pour les donnees brutes. Donnees anonymisees pour les statistiques agregees	A implementer (TTL index)
Integrite et confidentialite (Art. 5.1.f)	Identifiants stockes dans .env, MongoDB non expose, infrastructure Docker isolee	Conforme
Responsabilite (Art. 5.2)	Ce document constitue la preuve de conformite. Registre des traitements disponible	Conforme

3.2 Droits des personnes concernees (Articles 12 a 22)

Droit	Implementation	Procedure

Information (Art. 13-14)

Les utilisateurs de Bluesky publient des posts publics. L'information individuelle n'est pas requise pour les donnees publiques (exception Art. 14.5.b)



Exemption applicable

Acces (Art. 15)	Sur demande, nous pouvons fournir l'ensemble des donnees stockees pour un author_handle donne	Requete MongoDB : db.raw_posts.find({author_handle: "xxx"})
Rectification (Art. 16)	Les donnees textuelles ne sont pas modifiees. En cas de modification sur Bluesky, la version collectee reste la version au moment de la collecte	Note : la rectification du score IA est possible via recalcul
Effacement (Art. 17)	Suppression sur demande de tous les posts d'un utilisateur	Requete : db.raw_posts.deleteMany({author_handle: "xxx"}) - delai < 5 secondes
Limitation (Art. 18)	Possibilite de marquer des posts comme "non traitables" pour exclure des analyses	Champ ai_processed: "excluded"
Portabilite (Art. 20)	Export JSON des donnees d'un utilisateur sur demande	mongoexport --query '{author_handle: "xxx"}
Opposition (Art. 21)	Droit d'opposition au traitement. En cas d'exercice, effacement complet et ajout du handle dans une liste d'exclusion	A implementer (liste noire de collecte)
Decision automatisee (Art. 22)	Le score de credibilite est un indicateur, pas une decision automatisee produisant des effets juridiques	Non applicable

3.3 Registre des traitements (Article 30)

Champ	Valeur
Responsable de traitement	Azelie Bernard - Master Big Data
Finalite	Recherche academique : detection de desinformation sur reseaux sociaux
Base legale	Interet legitime (Art. 6.1.f)
Categories de personnes	Utilisateurs publics de Bluesky
Categories de donnees	Textes publics, pseudonymes (handles), dates, metriques d'engagement
Destinataires	Equipe projet uniquement
Transferts hors UE	Oui (API Bluesky hebergee aux USA) - donnees publiques
Duree de conservation	12 mois (donnees brutes), indefinie (statistiques anonymisees)
Mesures de securite	Chiffrement au repos (a implementer), isolation reseau Docker, identifiants en .env

4. Conformite AI Act (Reglement UE 2024/1689)

4.1 Classification du systeme

L'AI Act classe les systemes d'IA en 4 niveaux de risque. Determinons la classification de Thumalien.

Niveau	Description	Thumalien ?
Risque inacceptable (Art. 5)	Systemes de scoring social, manipulation subliminale, identification biometrique en temps reel	Non
Haut risque (Annexe III)	Systemes utilises dans l'emploi, l'education, les services essentiels, la justice, l'immigration	Non
Risque limite (Art. 52)	Systemes generant du contenu ou interagissant avec des personnes	Partiellement
Risque minimal	Tous les autres systemes	Oui

Classification retenue : Risque limite a minimal

Justification :

- Thumalien ne prend aucune decision automatisee affectant des droits fondamentaux
- Le score de credibilite est un outil d'aide a la decision, pas un verdict
- Le systeme ne genere pas de contenu et ne manipule pas d'information
- Il ne cible pas de personnes vulnerables
- Il n'est pas utilise dans un domaine a haut risque (emploi, justice, sante)

4.2 Obligations applicables (risque limite)

Obligation (Art. 52)	Implementation	Statut
Transparence : informer que le contenu est genere/analyse par une IA	Le dashboard affiche clairement que les scores sont produits par un modele d'IA. La page "Metriques & Transparence" detaille le fonctionnement	Conforme
Information sur les limites	La page Metriques documente les limites : pas de verification factuelle, biais thematique, langues limitees	Conforme
Documentation technique	Ce document + rapport technique + model card	Conforme

4.3 Bonnes pratiques volontaires (au-dela des obligations)

Bien que non obligatoires pour un systeme a risque limite, nous appliquons volontairement les bonnes pratiques suivantes, par souci d'excellence :

Bonne pratique	Implementation	Motivation
Explicabilite	Fonction explain_prediction() : top mots, features linguistiques, mots sensationnalistes	Permettre a l'utilisateur de comprendre et contester une prediction

Audit de biais	Ecart F1 FR/EN < 2 points. Biais Reuters identifie et corrige. Documentation des limites	Prevenir la discrimination algorithmique
Supervision humaine	Le score est un indicateur - aucune action automatisee n'est declenchee	Maintenir le controle humain
Empreinte carbone	CodeCarbon mesure chaque entrainement. Choix delibere de modeles frugaux	Responsabilite environnementale
Model card	Documentation du modele : architecture, donnees d'entrainement, performances, limites	Transparence pour les pairs et les regulateurs
Droit de contestation	Mecanisme de feedback prevu : si un utilisateur juge une prediction erronee, l'information est enregistree	Recours humain contre les erreurs de l'IA

4.4 Model Card - Fiche d'identite du modele

NOM DU MODELE : Thumalien Expert Detector V2
 TYPE : Classification binaire (Fiable / Suspect)
 ARCHITECTURE : TF-IDF (30K) + 12 features linguistiques + 7 emotions -> LogisticRegression calibree
 DONNEES D'ENTRAINEMENT : 145 703 textes (6 datasets : ISOT EN, Kaggle FR, FakeNewsNet, CONSTRAINT...
 LANGUES : Francais, Anglais
 PERFORMANCE :
 - F1 CV global : 0.897
 - F1 holdout : 0.90
 - Accuracy holdout : 93%
 - F1 textes courts (< 30 mots) : 0.80
 SEUIL DE DECISION : 0.44
 LIMITES CONNUES :
 - Ne verifie pas la veracite factuelle, detecte des patterns stylistiques
 - Performance reduite sur textes < 15 mots
 - Biais thematique vers la politique US et le COVID-19
 - Langues autres que FR/EN non supportees
 - Le modele peut evoluer dans le temps (concept drift)
 USAGE PREVU : Aide a la decision pour analystes, journalistes, chercheurs
 USAGE PROSCRIT : Censure automatisee, profilage individuel, decisions juridiques
 EMPREINTE CARBONE : 0.30 g CO2 (entrainement complet)
 DATE D'ENTRAINEMENT : Fevrier 2026
 RESPONSABLE : Azelie Bernard

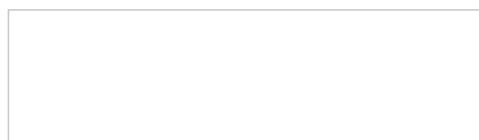
5. Mesures techniques de protection des donnees

5.1 Mesures implementees

Mesure	Detail	Statut

Isolation reseau

MongoDB accessible uniquement via le reseau
Docker interne (thumalien_network)



Implementee

Gestion des secrets	Identifiants Bluesky et MongoDB dans .env, fichier exclu du versionning (.gitignore)	Implementee
Pas de port expose	En production, seul le port 8501 (Streamlit) est expose	Implementee
Minimisation	Seuls les champs necessaires sont collectes (pas de profil complet, pas de followers)	Implementee
Logs	Les operations de collecte sont loguees (volume, erreurs)	Implementee

5.2 Mesures a implementer (plan d'action)

Mesure	Priorite	Echeance	Responsable
Index TTL sur MongoDB (suppression automatique apres 12 mois)	Haute	T2 2026	Data Engineer
Liste d'exclusion des handles (droit d'opposition)	Haute	T2 2026	Data Engineer
Hachage des handles dans la base (pseudonymisation renforcee)	Moyenne	T3 2026	Data Engineer
Chiffrement au repos de MongoDB	Moyenne	T3 2026	DevOps
Scan de vulnerabilites des images Docker (Trivy)	Haute	T2 2026	DevOps
Mecanisme de feedback utilisateur (contester une prediction)	Moyenne	T3 2026	Dashboard Dev
Audit annuel de conformite	Haute	T2 2027	Chef de Projet

6. Procedures operationnelles

6.1 Procedure d'exercice du droit d'effacement

1. L'utilisateur envoie une demande a l'adresse du responsable de traitement
2. Verification de l'identite du demandeur (correspondance avec le handle Bluesky)
3. Execution de la suppression :

```
db.raw_posts.deleteMany({author_handle: "<handle>"})
```
4. Verification : `db.raw_posts.countDocuments({author_handle: "<handle>"}) == 0`
5. Confirmation ecrite au demandeur dans un delai de 30 jours (Art. 12.3)
6. Ajout du handle dans la liste d'exclusion de collecte

6.2 Procedure en cas de violation de donnees (Art. 33-34)

1. Detection de la violation (monitoring, alerte, signalement)
2. Evaluation de la gravite :
 - Donnees concernees (textes publics, handles)
 - Nombre de personnes impactees
 - Risque pour les droits et libertes
3. Si risque eleve :
 - Notification a la CNIL dans les 72 heures (Art. 33)
 - Notification aux personnes concernees (Art. 34)
4. Documentation de l'incident et des mesures correctives
5. Mise a jour des mesures de securite

6.3 Procedure de retraining du modele

1. Declencheur : derive detectee, nouveau dataset disponible, ou planification mensuelle
2. Le Data Scientist prepare le nouveau dataset et documente les changements
3. Le ML Engineer entraine le nouveau modele et produit les metriques
4. Le Chef de Projet valide que les criteres d'acceptation sont respectes ($F1 \geq 0.85$)
5. L'Expert Green IT verifie l'empreinte carbone
6. Le MLOps deploye le nouveau modele avec rollback possible
7. Le registre des traitements est mis a jour
8. La model card est mise a jour

7. Synthese de conformite

Reglementation	Niveau de conformite	Actions restantes
RGPD - Principes fondamentaux	Conforme	TTL index a implementer
RGPD - Droits des personnes	Partiellement conforme	Liste d'exclusion a implementer
RGPD - Securite	Conforme	Chiffrement au repos recommande
RGPD - AIPD	Conforme	Ce document constitue l'AIPD
AI Act - Classification	Conforme	Risque limite a minimal
AI Act - Transparence	Conforme	Dashboard + documentation
AI Act - Documentation	Conforme	Model card + cahier des charges

Avis global : Le projet Thumalien presente un niveau de conformite satisfaisant pour un projet de recherche academique. Les mesures implementees couvrent les exigences principales du RGPD et de l'AI Act. Un plan d'action est defini pour les ameliorations restantes.

Document valide par la Direction Projet - Avril 2026

Prochaine revue : Octobre 2026

Reference : RGPD-THUM-2026-001 - Version 1.0